



UNIVERSIDAD TÉCNICA ESTATAL DE QUEVEDO
FACULTAD DE CIENCIAS DE LA COMPUTACIÓN Y
DISEÑO DIGITAL
CARRERA DE SOFTWARE

TEMA:

Evaluación Práctica Unidad II: Sistema CRUD de
Materias

ALUMNO:

CRUZ PEREZ JUSTYN KEITH

REPOSITORIO DE GITHUB:

`github.com/keithdrox/materias-CRUZ-PEREZ`

DOCENTE:

ING. GUERRERO ULLOA GLEISTON CICERON

MATERIA:

APLICACIONES WEB - A - [5to Nivel]

Quevedo - Ecuador
2026

1. Descripción de la Práctica

La presente práctica evaluativa de la Unidad II de la asignatura de Aplicaciones Web tiene como objetivo el diseño e implementación de un micro-sistema web seguro para la administración de las materias que ofrece la carrera de Ingeniería de Software.

El sistema fue desarrollado bajo la arquitectura Cliente-Servidor utilizando la pila tecnológica de **PHP 8.3** junto con el sistema de gestión de bases de datos relacionales **PostgreSQL**. La aplicación web asegura el acceso a la gestión de datos mediante un sistema de autenticación de administradores, protege la integridad de la base de datos con consultas SQL parametrizadas, y blindo la infraestructura contra ataques listados en el OWASP Top 10:2021.

El proyecto completo se ha estructurado de forma que sea fácilmente reproducible en cualquier entorno mediante el uso de contenedores con **Docker** y **Docker Compose**.

2. Capturas de Pantalla

2.1. Login del Sistema

Sistema de Materias

Iniciar Sesión

Usuario:
Contraseña:

Figura 1: Pantalla de inicio de sesión seguro.

2.2. Listado de Materias

Sistema de Materias

[Cerrar Sesión](#)
[Lista de Materias](#)

Listado de Materias

[Nueva Materia](#)

ID Código Nombre Créditos Semestre Acciones

Figura 2: CRUD: Visualización y listado en tabla.

2.3. Creación de Materia (Alta)

Sistema de Materias

[Cerrar Sesión](#)
[Lista de Materias](#)

Nueva Materia

Código:
Nombre:
Créditos (1-6):
Semestre (1-10):

Figura 3: CRUD: Formulario para el alta de materias.

2.4. Edición de Materia

Sistema de Materias

[Cerrar Sesión](#)
[Lista de Materias](#)

Editar Materia

Código:
Nombre:
Créditos (1-6):
Semestre (1-10):

Figura 4: CRUD: Formulario de actualización poblado con datos previos.

2.5. Eliminación Lógica

Sistema de Materias

[Cerrar Sesión](#)
[Lista de Materias](#)

Listado de Materias

[Nueva Materia](#)

ID	Código	Nombre	Créditos	Semestre	Acciones
----	--------	--------	----------	----------	----------

Figura 5: CRUD: Reflejo en tabla tras eliminación lógica.

3. Requisitos Implementados

3.1. Arquitectura y Despliegue con Docker

El repositorio incluye un archivo `docker-compose.yml` que configura y levanta tanto el contenedor web (PHP 8.3 y Apache) como el de la base de datos (PostgreSQL 15). Se crearon scripts en la carpeta `db/` (`schema.sql` y `seed.sql`) que inicializan automáticamente el esquema de datos y el usuario semilla con contraseña hasheada, permitiendo que la aplicación se levante con el único comando `docker compose up -d --build`.

3.2. Patrón de Diseño MVC y Capas

El sistema está diseñado bajo el patrón Modelo-Vista-Controlador y separa las responsabilidades de forma estricta:

- **Controlador:** Recibe las peticiones HTTP, verifica los tokens CSRF y gestiona las sesiones (`MateriaController.php`, `AuthController.php`).
- **Servicio:** Lógica central que valida rangos, longitudes y unicidad de la información (`MateriaService.php`).
- **Repositorio (DAO):** Única capa con acceso directo a la base de datos mediante extensiones PDO, aislando las sentencias SQL (`MateriaRepository.php`).

3.3. Seguridad OWASP Top 10

Se han aplicado rigurosas medidas defensivas exigidas en la rúbrica:

- **Inyección SQL:** Totalmente mitigada en la capa Repositorio al prohibirse la concatenación de datos del usuario, utilizando el formato paramétrico seguro de PDO (`:codigo`, `:nombre`, etc.).
- **Cross-Site Scripting (XSS):** Todo el flujo de salida dinámico que interactúa con las vistas HTML es sistemáticamente escapado usando `htmlspecialchars(..., ENT_QUOTES, 'UTF-8')`.
- **CSRF:** Cada formulario originado por el método POST es validado en el servidor contra un token secreto y aleatorio (`random_bytes(32)`) persistido en sesión. La comprobación se ejecuta en tiempo constante vía `hash_equals`.
- **Cabeceras HTTP de Defensa:** Se emitieron las directivas de protección globales: `Strict-Transport-Security`, `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff` y un `Content-Security-Policy` básico restrictivo.

3.4. Autenticación, Hashes y Sesiones

El usuario semilla 'admin' se crea con la clave 'Admin*2026' protegida bajo algoritmo **BCrypt** directamente en la base de datos. La gestión de sesiones rechaza cualquier petición a una ruta de la aplicación (distinta al login) con un código HTTP 302 hacia '/login'. Las cookies de sesión operan bajo las banderas de seguridad `HttpOnly=true` y `SameSite=Strict`.

4. Decisiones Técnicas

Conforme a los requerimientos, las decisiones documentadas en la carpeta docs justifican la separación por capas (evitar código espagueti y mejorar testabilidad), la implementación rigurosa de PDO (frente a librerías inseguras o funciones arcaicas como `mysql_query`) y las múltiples validaciones duales (tanto atributos HTML5 requeridos en cliente como rechazos controlados 422 en el backend).



Revisión de intento

APLICACIONES WEB - SOFT-R - A - [5TO NIVEL] | CORTE 1

Estudiante	CRUZ PEREZ JUSTYN KEITH
Comenzado el	Viernes, 3 de Julio de 2026, 07:59
Intento	1 / 1
Estado	Finalizado
Finalizado en	Viernes, 3 de Julio de 2026, 08:07
Tiempo empleado	0:08:27.074007
Calificación obtenida	3.00 / 20.00
Calificación final	1.50 / 10.00

PREGUNTA

1

Finalizado

0.00 / 1.00

En ASP.NET Core, ¿cuál es el servidor de aplicaciones embebido, multiplataforma y de alto rendimiento que atiende las peticiones HTTP?

Seleccione una alternativa:

- ☒ a. Apache Tomcat. ✖
- ☐ b. IIS.
- ☐ c. Apache HTTPS.
- ☐ d. Kestrel.

La respuesta correcta es: Kestrel.

PREGUNTA

2

Finalizado

0.00 / 1.00

En la clasificación OWASP Top 10:2021 utilizada en el libro, ¿cuál categoría corresponde al identificador A03?

Seleccione una alternativa:

- ☐ a. Broken Access Control.
- ☐ b. Cryptographic Failures.
- ☐ c. Injection.
- ☒ d. Insecure Design. ✖

La respuesta correcta es: Injection.

PREGUNTA

3

Finalizado

0.00 / 1.00

Según la tabla evolutiva del libro, ¿en qué versión de PHP se introdujo el compilador JIT junto con named arguments, attributes y la expresión match?

Seleccione una alternativa:

- ☐ a. PHP 8.0.
- ☐ b. PHP 7.0.
- ☒ c. D) PHP 8.1. ✖
- ☐ d. PHP 7.4.

La respuesta correcta es: PHP 8.0.

PREGUNTA

4

Finalizado

0.00 / 1.00

¿Qué cabecera de respuesta HTTP indica al navegador que debe forzar HTTPS durante un tiempo prolongado (por ejemplo un año, max-age=31536000)?

Seleccione una alternativa:

- ☐ a. X-Content-Type-Options.
- ☒ b. X-Frame-Options. ✖
- ☐ c. Content-Security-Policy.
- ☐ d. Strict-Transport-Security.

La respuesta correcta es: Strict-Transport-Security.

PREGUNTA

5

Finalizado

1.00 / 1.00

¿Qué función de PHP debe usarse hoy para almacenar de forma segura la contraseña de un usuario, usando internamente BCrypt o Argon2?

Seleccione una alternativa:

- ☒ a. password_hash(\$clave, PASSWORD_DEFAULT). ✔
- ☐ b. md5(\$clave).
- ☐ c. htmlspecialchars(\$clave, ENT_QUOTES).
- ☐ d. sha1(\$clave).

La respuesta correcta es: password_hash(\$clave, PASSWORD_DEFAULT).

PREGUNTA

6

Finalizado

0.00 / 1.00

¿Cuál superglobal de PHP contiene los datos enviados desde un formulario HTML con el atributo method="post"?

Seleccione una alternativa:

- ☐ a. \$_POST.
- ☐ b. \$_SERVER.
- ☐ c. \$_SESSION.
- ☒ d. \$_GET. ✖

La respuesta correcta es: \$_POST.

PREGUNTA

7

Finalizado

0.00 / 1.00

Según el capítulo de ASP.NET Core del libro, ¿en qué año Microsoft lanzó ASP.NET Core 1.0 convirtiéndolo en una plataforma open source, multiplataforma y modular?

Seleccione una alternativa:

- ☐ a. 1996.
- ☐ b. 2009.
- ☒ c. 2002. ✖
- ☐ d. 2016

La respuesta correcta es: 2016

PREGUNTA

8

Finalizado

1.00 / 1.00

En un proyecto ASP.NET Core Web API, ¿qué atributo se coloca sobre la clase del controlador para habilitar la validación automática del modelo y el enlazado desde el cuerpo JSON?

Seleccione una alternativa:

- ☒ a. [ApiController]. ✔
- ☐ b. [Route("api/[controller]")].
- ☐ c. [HttpGet].
- ☐ d. [HttpPost].

La respuesta correcta es: [ApiController].

PREGUNTA

9

Finalizado

0.00 / 1.00

¿Qué flag de una cookie garantiza que el navegador solo la envíe por conexiones cifradas HTTPS, y nunca por HTTP en claro?

Seleccione una alternativa:

- ☐ a. Path=/.
- ☐ b. Secure.
- ☐ c. SameSite=Lax.

☐ d. HttpOnly. ✖

La respuesta correcta es: Secure.

PREGUNTA

10

Finalizado

0.00 / 1.00

Según el capítulo de gestión de estado y de seguridad, ¿cuál flag de una cookie de sesión impide que JavaScript en el navegador pueda leerla mediante document.cookie y por tanto es la defensa principal contra el robo de sesión por XSS?

Seleccione una alternativa:

- ☐ a. HttpOnly.
- ☒ b. Max-Age. ✖
- ☐ c. Secure.
- ☐ d. SameSite=Strict.

La respuesta correcta es: HttpOnly.

PREGUNTA

11

Finalizado

0.00 / 1.00

En Spring Boot, ¿qué anotación estereotipo corresponde a la capa de negocio (servicios de aplicación, casos de uso, reglas de dominio)?

Seleccione una alternativa:

- ☐ a. @Controller.
- ☐ b. @Service.
- ☒ c. @WebControllers ✖
- ☐ d. @Services
- ☐ e. @RestController.
- ☐ f. @Repository.

La respuesta correcta es: @Service.

PREGUNTA

12

Finalizado

0.00 / 1.00

Según el capítulo de seguridad del libro (OWASP Top 10:2021, A03 Injection), ¿cuál es la única defensa recomendada como 100% efectiva contra la inyección SQL en PHP?

Seleccione una alternativa:

- ☐ a. Sentencias preparadas de PDO con marcadores.
- ☐ b. Añadir la cabecera Content-Security-Policy: default-src 'self'.
- ☐ c. Escapar la entrada con htmlspecialchars antes del SELECT.
- ☒ d. Aplicar password_hash al valor recibido del usuario. ✖

La respuesta correcta es: Sentencias preparadas de PDO con marcadores.

PREGUNTA

13

Finalizado

0.00 / 1.00

En una aplicación web con formularios tradicionales, ¿cuál es la defensa habitual descrita en el material contra el ataque Cross-Site Request Forgery (CSRF)?

Seleccione una alternativa:

- ☐ a. Usar sentencias preparadas PDO con marcadores nombrados.
- ☐ b. Escapar toda salida con htmlspecialchars y ENT_QUOTES.
- ☐ c. Incluir un token secreto e impredecible que el servidor genera y verifica.
- ☒ d. Almacenar las contraseñas con BCrypt. ✖

La respuesta correcta es: Incluir un token secreto e impredecible que el servidor genera y verifica.

PREGUNTA

14

Finalizado

0.00 / 1.00

¿En qué año creó Larry Wall el lenguaje PERL (Practical Extraction and Report Language)?

Seleccione una alternativa:

- ☐ a. 1987.
- ☐ b. 1993.
- ☐ c. 1994.

☐ d. 1996. ✖

La respuesta correcta es: 1987.

PREGUNTA

15

Finalizado

1.00 / 1.00

En la guía de Java web del curso, ¿cuál es el contenedor de servlets utilizado como servidor de aplicación para desplegar el archivo .war generado por Maven?

Seleccione una alternativa:

- ☐ a. Apache HTTPD.
- ☐ b. Nginx.
- ☒ c. Apache Tomcat. ✔
- ☐ d. IIS.

La respuesta correcta es: Apache Tomcat.

PREGUNTA

16

Finalizado

0.00 / 1.00

En un servlet Java (Jakarta Servlet 6.1), ¿qué anotación asocia la clase servlet con la URL en la que responderá?

Seleccione una alternativa:

- ☐ a. @Controller.
- ☐ b. @RestController.
- ☐ c. @WebServlet.
- ☒ d. @GetMapping. ✖

La respuesta correcta es: @WebServlet.

PREGUNTA

17

Finalizado

0.00 / 1.00

¿Quién creó, en 1994, el conjunto de scripts CGI en PERL que dio origen al lenguaje PHP?

Seleccione una alternativa:

- ☐ a. Zeev Suraski.
- ☒ b. Larry Wall. ✖
- ☐ c. Rasmus Lerdorf.
- ☐ d. Andi Gutmans.

La respuesta correcta es: Rasmus Lerdorf.

PREGUNTA

18

Finalizado

0.00 / 1.00

El libro señala que ASP.NET Core soporta tres estilos de aplicación web: Web API (solo JSON, sin vistas), MVC (con controllers, vistas y modelos) y un tercer estilo en el cual cada página tiene su propio PageModel. ¿Cuál es ese tercer estilo?

Seleccione una alternativa:

- ☐ a. Razor Pages.
- ☐ b. Blazor.
- ☒ c. Windows Forms. ✖
- ☐ d. WebForms.

La respuesta correcta es: Razor Pages.

PREGUNTA

19

Finalizado

0.00 / 1.00

En un proyecto Java web organizado por capas (patrón MVC), ¿dónde deben colocarse las páginas JSP para que no sean accesibles directamente desde el navegador y solo se sirvan a través de un servlet?

Seleccione una alternativa:

- ☐ a. src/main/java.
- ☐ b. src/main/webapp/WEB-INF/vistas.
- ☒ c. src/main/resources/templates. ✖
- ☐ d. src/main/webapp (raíz).

La respuesta correcta es: src/main/webapp/WEB-INF/vistas.

PREGUNTA

20

Finalizado

0.00 / 1.00

¿Qué cabecera HTTP, configurada con el valor DENY, impide que la página se cargue dentro de un <iframe> ajeno y bloquea así el clickjacking?

Seleccione una alternativa:

- ☐ a. Permissions-Policy: geolocation=().
- ☒ b. Referrer-Policy: strict-origin-when-cross-origin. ✖
- ☐ c. X-Content-Type-Options: nosniff.
- ☐ d. X-Frame-Options: DENY.

La respuesta correcta es: X-Frame-Options: DENY.

NAVEGACIÓN

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

Correcto ☐ Parcial ☐ Incorrecto ☐